

NÚCLEO DE PESQUISA: PRIVACIDADE E PROTEÇÃO DE DADOS NA UTILIZAÇÃO DE INTELIGÊNCIA ARTIFICIAL GENERATIVA DURANTE O DESENVOLVIMENTO DE SOFTWARE

Esta pesquisa normativa, técnica e acadêmica analisa as implicações legais e os riscos de privacidade associados ao uso de Inteligência Artificial Generativa no desenvolvimento de software, priorizando o arcabouço normativo brasileiro (LGPD/ANPD) e as evidências técnicas de vazamento de dados.

A. DELIMITAÇÃO

A pesquisa delimita-se à intersecção entre o desenvolvimento de código-fonte assistido por IA e as obrigações estatais de proteção de dados. O escopo abrange os riscos gerados quando desenvolvedores inserem dados reais, credenciais ou segredos industriais em prompts de Modelos de Linguagem de Larga Escala (LLMs), analisando a legalidade dessas ações sob a Lei Geral de Proteção de Dados Pessoais (LGPD) e as políticas de retenção das provedoras de IA.

B. PERGUNTAS DE PESQUISA

1. Como a LGPD e as diretrizes da ANPD regulamentam o compartilhamento de dados pessoais, anonimizados e sensíveis com serviços de IA de terceiros durante o desenvolvimento de sistemas?
2. Quais são os riscos técnicos comprovados de extração de dados e exposição de credenciais/código-fonte enviados aos LLMs?
3. Quais cuidados de privacidade e proteção de dados devem ser incorporados ao uso de IA generativa durante o desenvolvimento de software para garantir conformidade legal e segurança sistêmica?

C. SUBTEMAS INVESTIGADOS

- Normatividade (LGPD): Dados pessoais e sensíveis, finalidade, necessidade, segurança, transparência, prevenção e responsabilização.

- Engenharia Assistida: Compartilhamento de dados reais em prompts, envio de código-fonte, exposição de credenciais e informações institucionais.
- Tratamento e Retenção: Políticas de armazenamento dos provedores, treinamento de modelos de IA com dados de usuários, técnicas de anonimização, pseudonimização e minimização.
- Riscos Técnicos: Extração de dados de treinamento, exposição de propriedade intelectual e falhas no controle de acesso.

D. ESTRATÉGIA E CRITÉRIOS DE SELEÇÃO

A fundamentação ancorou-se primariamente em fontes oficiais do Direito brasileiro: a LGPD (Lei 13.709/2018) e resoluções/guias da Autoridade Nacional de Proteção de Dados (ANPD) vigentes até 2026. Em segundo plano, analisou-se a documentação de conformidade e termos de serviço de provedores de IA (reconhecendo sua natureza comercial). Por fim, literatura acadêmica recente (2021-2026) sobre segurança ofensiva em LLMs foi utilizada para fundamentar as ameaças de vazamento de dados.

E. FONTES E F. EVIDÊNCIAS EXTRAÍDAS

Fonte 1: LGPD (Lei nº 13.709/2018)

Natureza: Legislação Federal Brasileira.

Obrigaç o Legal e Evid ncia: O Art. 5 , incisos I e II, define dados pessoais e sens veis. O Art. 6  estabelece princ pios inegoci veis para o tratamento: 'finalidade' (tratamento para prop sitos leg timos e expl citos), 'necessidade' (minimiza o, usando apenas os dados estritamente necess rios) e 'seguran a' (medidas t cnicas para proteger os dados de acessos n o autorizados). O Art. 12 trata da anonimiza o.

Aplica o: Inserir um banco de dados real de clientes ou alunos em um prompt de IA p blica para gerar uma consulta SQL viola diretamente a LGPD, pois caracteriza compartilhamento n o autorizado com terceiros e desvio de finalidade.

Fonte 2: ANPD - Diretrizes sobre Inteligência Artificial

Natureza: Orientação/Normativa Regulatória (Órgão Público Brasileiro).

Obrigações Legais e Evidências: A ANPD estabelece que o tratamento de dados pessoais no ciclo de vida de sistemas de IA (incluindo o desenvolvimento) deve ser pautado pela minimização e que a anonimização irreversível é o padrão recomendado. A prestação de contas (accountability) exige que as empresas demonstrem a rastreabilidade do envio de dados a plataformas em nuvem.

Fonte 3: Termos de Serviço de Provedores de IA (Ex: OpenAI, Google Cloud)

Natureza: Documentação Oficial Corporativa (Não é evidência científica).

Evidências: A documentação técnica desses provedores estabelece uma dicotomia clara. Nas versões gratuitas ou de consumo (web), os prompts e dados enviados *são* retidos e utilizados para treinar modelos futuros por padrão. Nas versões corporativas (Enterprise/API pagas), os provedores declaram conformidade com SOC 2 e não utilizam os dados do cliente para treinamento.

Aplicação: O risco varia conforme o licenciamento. Usar a versão gratuita de um LLM no trabalho é um risco de segurança e de quebra de sigilo industrial.

Fonte 4: CARLINI, N. et al. (2021) / Estudos de Segurança em LLMs

Natureza: Artigo Científico / Segurança da Informação.

Ano: 2021.

Título: Extracting Training Data from Large Language Models.

Evidências: Estudo empírico que prova ser possível extrair dados literais de treinamento (incluindo nomes, telefones e trechos de código confidencial) de um modelo de linguagem estocástico através de ataques de injeção de prompt. Fundamenta tecnicamente o porquê enviar dados não anonimizados a uma IA pública é perigoso.

G. ANÁLISE CRÍTICA

A análise revela uma falsa sensação de segurança entre desenvolvedores. Muitos acreditam que, por não estarem 'publicando' dados na internet de forma convencional, o envio de um arquivo JSON com dados de clientes para o ChatGPT depurar um erro é seguro. Contudo, do ponto de vista legal (LGPD), isso é um incidente de vazamento

(Data Breach). A literatura acadêmica de cibersegurança corrobora as restrições da LGPD ao provar que modelos de IA sofrem de 'memorização não intencional'. Assim, a obrigação de 'Prevenção' (Art. 6º, VIII) exige que o controle de privacidade ocorra antes do prompt ser submetido, por meio de Data Masking (mascaramento de dados) ou pseudonimização.

H. COMPOSIÇÃO ACADÊMICA ÚNICA

A integração de ferramentas de Inteligência Artificial Generativa nas rotinas de Engenharia de Software introduziu um vetor inédito de riscos à privacidade e proteção de dados. No ordenamento jurídico brasileiro, a Lei Geral de Proteção de Dados (LGPD) impõe que qualquer tratamento de dados — incluindo a leitura, transmissão ou armazenamento — obedeça aos princípios da finalidade, necessidade e segurança (Art. 6º). Quando um desenvolvedor, buscando acelerar a depuração ou refatoração de um sistema, submete logs de erro, dumps de banco de dados ou código-fonte contendo informações reais de usuários a um Modelo de Linguagem de Larga Escala (LLM), ele configura uma transferência não autorizada de dados para a infraestrutura do provedor da IA.

A documentação técnica dos principais provedores comerciais atesta que, nas modalidades gratuitas ou de uso geral, o conteúdo dos prompts é retido para retroalimentar o treinamento dos modelos de fundação. Essa prática comercial colide frontalmente com o princípio da Prevenção e da Responsabilização da LGPD e atrai sanções regulatórias da Autoridade Nacional de Proteção de Dados (ANPD). Ademais, a literatura de cibersegurança (como o estudo fundacional de Carlini et al., 2021) comprova empiricamente o fenômeno da memorização de LLMs: dados sensíveis utilizados em treinamento podem ser extraídos reversamente por terceiros mediante ataques adversariais de prompt.

Diante disso, quais cuidados de privacidade e proteção de dados devem ser incorporados ao uso de IA generativa durante o desenvolvimento de software? A resposta repousa em uma governança estrita de 'Privacidade desde a Concepção' (Privacy by Design). É mandatório estabelecer políticas de Controle de Acesso e Sanitização de

Contexto. Nenhuma credencial (senhas, tokens de API), informação confidencial de infraestrutura ou dado pessoal (mesmo que apenas nomes e e-mails) deve compor a janela de contexto de uma IA. A Engenharia de Software assistida exige que a técnica de 'Minimização' seja aplicada: os desenvolvedores devem empregar dados sintéticos (fictícios) e aplicar anonimização irreversível aos artefatos antes de solicitar a intervenção da IA para testes ou depuração. A delegação de automação à máquina encerra-se onde a exposição de dados regulados começa.

I. APLICAÇÃO PRÁTICA NA TG

No escopo do Trabalho de Graduação focado na FATEC Barueri, o sistema de grade horária lida intrinsecamente com a identidade institucional de professores e o registro acadêmico de alunos. As regras estabelecidas abaixo consolidam as mitigações legais e técnicas exigidas.

Dado / Informação	Risco	Fundamento Legal / Técnico	Medida Preventiva	Aplicação na TG
Nomes, E-mails e RA dos alunos	Vazamento de dados pessoais; exposição e memorização pelo LLM.	LGPD, Art. 5º, I (Dado Pessoal) e Art. 6º, VII (Segurança).	Anonimização e uso de dados estritamente sintéticos (Fake Data).	Proibição absoluta de colar consultas SQL no ChatGPT contendo matrículas reais da FATEC.
Carga horária e alocação de Professores	Violação de privacidade institucional e quebra de sigilo profissional.	LGPD (Finalidade) e Políticas de Provedores (retenção para treinamento).	Minimização e Pseudonimização (substituição por variáveis genéricas).	Para gerar o algoritmo de choque de horário, os nomes dos professores serão substituídos por "Prof_A", "Prof_B".
Tokens de API, Senhas do MySQL e Keys JWT	Risco crítico de invasão da infraestrutura; comprometimento do repositório.	Estudos de Segurança (Vulnerabilidades de credenciais hardcoded).	Uso de arquivos .env; bloqueio de envio no prompt.	O código-fonte submetido à IA para Code Review terá os arquivos de configuração e credenciais de banco deletados do contexto.

J. REFERÊNCIAS ABNT COMPLETAS

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS (ANPD). Guias e Enunciados sobre Inteligência Artificial e Tratamento de Dados Pessoais. Brasília, DF: ANPD, 2024. Disponível em: portal oficial da ANPD.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018.

CARLINI, N. et al. Extracting Training Data from Large Language Models. Em: Proceedings of the 30th USENIX Security Symposium. [S. l.]: USENIX Association, 2021. p. 2633-2650.

K. LACUNAS DE INVESTIGAÇÃO

- A atual regulamentação (LGPD) baseia-se na concepção tradicional de bancos de dados relacionais e sistemas determinísticos. A exclusão definitiva (Direito ao Esquecimento - Art. 18) de um dado pessoal que foi estatisticamente incorporado aos pesos neurais de um LLM ainda representa um problema insolúvel tanto técnica quanto juridicamente.
- A eficácia de ferramentas de 'Data Loss Prevention (DLP)' incorporadas nativamente a IDEs (que bloqueiam credenciais antes delas irem para o Copilot localmente) carece de avaliação acadêmica independente sobre suas taxas de falso-positivo e falso-negativo.